Truncated SHA-2

Collision Resistance of Prefixes and Digital Signatures

Data Security

November 3, 2026

Abstract

A system that accepts a SHA-256 digest after keeping only its most significant n bits has a much smaller collision bound than the full hash. This note states the assignment: measure that loss, and judge what it means for a digital signature computed on the truncated digest. The concrete setting is the poisoned-message story of Alice and her employer, replayed for H_n instead of MD5.

1 Your mission

1. Replay Alice's investigation and determine how secure the truncated hash function, and the digital signature on top of it, really are.
2. Find a realistic attack against meaningful messages. The construction itself will be covered in a later lecture.

The reference story is Daum and Lucks, *Hash Collisions (The Poisoned Message Attack)*:

`https://www.sos.cs.ru.nl/applications/courses/security2015/md5collisions/index.html`

In that story Alice prepares two PostScript documents that display different text (a letter of recommendation, and an order granting her access) but share one MD5 digest:

`a25f7f0b29ee0b3968c860738533a4b9`

A signature on the letter is therefore a valid signature on the order. The question here is the same one, asked of a prefix of SHA-256: once only n bits are checked, which pairs of messages become practical to find, and when does a signature on $H_n(x)$ stop distinguishing them?

2 What is SHA-2?

SHA-2 is a family of cryptographic hash functions standardized by NIST: SHA-224, SHA-256, SHA-384, and SHA-512. The functions are designed to be collision-resistant and preimage-resistant. They are widely used in digital signatures, TLS, and blockchain systems.

This assignment truncates SHA-256. Write $H(x)$ for the full 256-bit digest of a message x. A truncated check keeps the most significant n bits and discards the rest:

$$H_n(x) = \text{prefix}_n\big(H(x)\big). \tag{1}$$

The prefix is shorter than $H(x)$, so distinct messages collide under H_n more easily than under H. Truncation reduces collision resistance.

When a digest is written in hexadecimal, the leading digits are the most significant bits. For n a multiple of 4, $H_n(x)$ is the first $n/4$ hex digits of $H(x)$.

3 Most and least significant bits

Bits of a byte are written left to right, from the most significant bit (MSB) to the least significant bit (LSB). Figure 1 uses the same example as the lecture, the byte `01100100`.

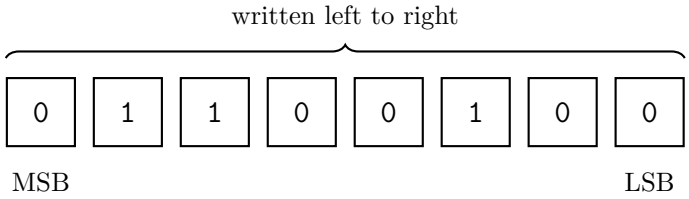


Figure 1: One byte, most significant bit on the left. prefix_n keeps the leftmost n bits of this ordering, scaled up to the 256-bit SHA-256 digest.

Table 1: Names of the bits in `01100100`. Place values show why the left-hand bits dominate the integer value of the byte ($64 + 32 + 4 = 100$).

From the left	Bit	Place value	Name
1	0	2^7	Most significant bit
2	1	2^6	2nd most significant bit
3	1	2^5	3rd most significant bit
4	0	2^4	4th most significant bit
5	0	2^3	5th most significant bit
6	1	2^2	6th most significant bit
7	0	2^1	7th most significant bit
8	0	2^0	Least significant bit

The same left-to-right convention applies to a SHA-256 digest. $H_n(x)$ in (1) is the block of n bits that starts at the MSB and runs toward the LSB. The discarded bits are the less significant tail.

4 Collision-attack complexity

A collision is a pair of distinct inputs with the same truncated digest:

$$x \neq x' \quad \text{and} \quad H_n(x) = H_n(x').$$

The best known generic attack is still the birthday attack. Its cost is

$$\boxed{O(2^{n/2})} \tag{2}$$

Truncation therefore gives at most $n/2$ bits of collision security. A full SHA-256 digest has $n = 256$, and the same bound is 2^{128}. Every bit dropped from the prefix cuts the birthday cost in half.

5 Security implications

- Short prefixes allow practical collisions. The lecture's examples are $n = 32$ and $n = 64$, with birthday costs 2^{16} and 2^{32}.

- The truncated check is safe only when n is sufficiently large. The lecture's example threshold is $n \geq 128$, which leaves a birthday cost of at least 2^{64}.

A signature that covers $H_n(x)$ and ignores the remaining $256 - n$ bits accepts every message that lands in the same prefix. The signature is only as collision-resistant as H_n.

6 Required work

The experimental part of the assignment is a collision search on H_n. Include all of the following.

1. Find the largest n you can reach. Begin at $n = 32$ and move upward.
2. Find as many approaches as you can. The hinted starting points are a hash table and Floyd's cycle-finding algorithm.
3. Trade computation against memory, and parallelize the search. Report what each approach stores, how much work it does, and where the machine actually runs out of time or memory.

For each n you reach, record a concrete colliding pair and the shared prefix, together with the time and memory of the run. The interesting comparison is across methods at the same n: a hash table spends memory to detect a repeated prefix quickly, while a cycle-finding search stores a constant amount of state and pays for that with more hashing.

7 Goal of this topic

Understand how truncating SHA-2 outputs affects collision resistance, and why birthday-bound attacks dominate the analysis. The generic cost (2) is the yardstick: an attack that beats it on H_n would be a cryptanalytic result about SHA-256 itself, and a search that only matches it is still enough to show that a short prefix, and any signature reduced to that prefix, is weak.

The later lecture on meaningful messages asks for a collision the way Alice's is a collision: two inputs a person would accept as different documents, sharing H_n, so that one signature verifies on both. Until that construction is given, the measurement above is the evidence for the security conclusion.

References

[1] Magnus Daum and Stefan Lucks. Hash Collisions (The Poisoned Message Attack). Mirror used in the Security course at Radboud University, `https://www.sos.cs.ru.nl/applications/courses/security2015/md5collisions/index.html`.

[2] National Institute of Standards and Technology. *Secure Hash Standard (SHS)*, FIPS PUB 180-4, 2015.